MK FRAUD INSIGHTS

FRAUD READINESS · ESSENTIAL

Fraud Readiness Report

Kestrel Freight (Pty) Ltd (fictional)

Assessment reference MKFRS-2026-RV9C289E5F

13 November 2026

Confidential. Prepared for the management of Kestrel Freight (Pty) Ltd (fictional).

RESTRICTED TEST · Fictional organisation entered through the test deployment · Revised method not approved by MK: no readiness score is issued · Not for customer release

ABOUT THIS REPORT

This report connects the organisation's answers to practical control actions

This report explains the organisation's answers about fraud controls, draws out the patterns that emerge, develops selected weaknesses into operational observations, and sets out actions for leadership consideration. It moves from the overall position to the control arrangements that could reduce opportunities for diversion, impersonation and account misuse.

EXECUTIVE SUMMARY	The organisation reports broad control gaps alongside a small set of direct diversion routes
READINESS PROFILE	Reported control gaps extend across all assessed operational areas
WHAT IS DRIVING THE POSITION	Requester-controlled confirmation routes can enable impersonation and diversion
THE FINDINGS THIS REPORT DEVELOPS	Selected weaknesses show how routine requests could become fraud opportunities
	Salary changes can be redirected when payroll replies to the initiating request
	Hiring can admit a false identity when documents are accepted on appearance
	Fraudulent beneficiaries can be introduced when finance follows contact details in the request
	Customer changes can redirect funds or goods when unusual appearance is the trigger for challenge
	A help desk reset can give an impersonator access to an employee account
HOW FRAUD EXPOSURE COULD MATERIALISE	A compromised help desk process can support payment diversion through a genuine employee account
WHAT MANAGEMENT SHOULD DO FIRST	The controls set out first can reduce direct routes to diversion and impersonation
A 30, 60 AND 90 DAY RESPONSE	The proposed stages move from ownership to operation and oversight reporting
BASIS OF THIS REPORT	This assessment reflects the organisation's own answers and pending method approvals
MANAGEMENT CONCLUSION	Leadership can reduce direct fraud routes by establishing ownership and operating independent checks

EXECUTIVE SUMMARY

The organisation reports broad control gaps alongside a small set of direct diversion routes

The organisation reports that 73 fraud scenarios apply to its operations. It reports every core control in place for 2 scenarios, while a core control is reported as a gap in 55 scenarios. There are no scenarios requiring answers to be settled or clarified, although 12 scenarios cannot yet be read because core answers remain outstanding.

The overall picture is uneven because controls reported as absent extend across governance, people, finance, customer administration, digital access and response arrangements. The organisation's answers point particularly to a common operating weakness: important instructions may be accepted through channels controlled by the person making the request. That can allow an impersonator to influence a salary change, a beneficiary payment, a customer detail amendment or an account reset.

A separate pattern is uncertainty about whether key controls exist, who operates them and how they are applied. Questions remain with 5 functions, covering 13 outstanding questions. This uncertainty can delay containment and escalation when a suspicious payment, account compromise, allegation or customer impact needs an accountable response.

No score, maturity level or readiness conclusion is issued. The revised scoring approach has not been approved, and this assessment does not draw a readiness conclusion from the organisation's answers. Leadership should use the controls this report sets out first as a practical starting point while retaining the selection rules rather than treating them as a formal risk ranking.

The immediate management task is to establish clear ownership of unanswered controls and approve operating designs that require independent confirmation before money, identity details, customer records or account access can change. The chief financial officer, chief executive and board or its audit or risk committee each have a role in ensuring that this work becomes routine operational practice rather than an isolated policy exercise.

WHAT THE ASSESSMENT ESTABLISHES

SCORE

Not issued

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

UNRESOLVED INCONSISTENCIES

None found

None found. Most related practices were not asked, so this is not a finding that every answer is consistent.

PROVISIONAL MANAGEMENT INTERPRETATION

55 with a control reported as a gap

On its own answers, the organisation reports the core control in place for 2 of the 73 fraud scenarios that apply; 12 cannot yet be read because answers are outstanding; and 55 have a core control reported as a gap.

APPROVED READINESS CONCLUSION

None issued

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

Reported control gaps extend across all assessed operational areas

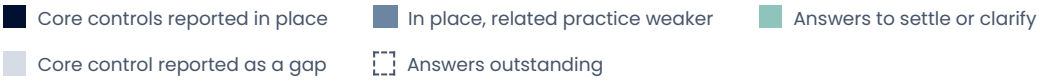
The organisation's answers show reported gaps in fraud governance and accountability, fraud risk assessment, ethics and anti-corruption, third parties, people, finance, customer administration, assets, digital activity and detection. The pattern is broad rather than concentrated in a single department, which means that leaders will need connected ownership across operational and support functions.

Governance and ethics arrangements show substantial reported gaps, while payroll, finance, customer administration and digital access create practical routes through which an external impersonator or dishonest insider could seek to obtain money, goods or access. These routes are linked because a compromise in one function can support action in another, such as a help desk reset followed by a payment instruction or bank-detail change.

The position also indicates that detection and response arrangements require attention alongside preventative controls. A payment or identity change may be stopped before loss only when staff know how to challenge unusual requests, escalate concerns, preserve relevant information and act quickly to contain a suspected compromise.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

AREA	SCENARIOS THAT APPLY	CORE CONTROLS IN PLACE	TEST FIGURE
Fraud governance and accountability		1 of 12	
Fraud risk assessment		1 of 6	
Ethics, integrity and anti-corruption		0 of 8	
Third parties and supply chain		0 of 2	
People, payroll and insider risk		0 of 8	
Finance, banking and financial reporting		0 of 8	
Customers, revenue and products		0 of 6	
Assets, cash and inventory		0 of 4	
Digital, cyber-enabled and identity fraud		0 of 11	
Detection, speak-up and response		0 of 8	



Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

WHAT IS DRIVING THE POSITION

Requester-controlled confirmation routes can enable impersonation and diversion

ACROSS THE ORGANISATION

Functions need clear answers about who owns key safeguards

The organisation reports 13 unanswered questions held across 5 functions. These questions concern suspicious transaction reporting, response decisions, declared interests, exceptions for senior people, payment recall, customer blocking, loss tracking, instruction handling, compromise procedures, privacy notification, speak-up arrangements and allegation intake.

Where a function does not know whether a safeguard exists or how it operates, staff may rely on local judgement when a concern arises. This can create delay in recalling a payment, responding to a compromised account, escalating an allegation or deciding who should communicate with affected people. Informal workarounds can also leave leadership without a consistent view of incidents, exceptions and unresolved concerns.

Leadership should require each unanswered control to have an accountable executive, a practical owner and a concise description of the intended operating process. The proposed opening stage should establish whether the control exists, where its supporting information is held and what action is required if the control is absent or incomplete.

ACROSS THE ORGANISATION

Independent confirmation should replace reliance on incoming requests

The organisation's answers describe 8 practices across 4 areas where instructions that move money or change identity may be accepted through the requester's own communication route. Payroll, finance, customer administration and digital access are all affected by this pattern.

An email reply, incoming call, supplied telephone number or convincing voice may appear legitimate while still being controlled by an impersonator. If the organisation uses those channels as the sole basis for confirmation, an attacker may direct salary payments, introduce a fraudulent beneficiary, amend customer details or obtain access to an employee account.

The control response is to initiate confirmation through contact information already held by the organisation, use an authoritative source for identity checks, and separate request handling from approval or amendment where the process permits. The chief financial officer should ensure that the relevant functional leads adopt consistent procedures during the proposed implementation stage.

THE FINDINGS THIS REPORT DEVELOPS

Selected weaknesses show how routine requests could become fraud opportunities

The findings below were selected using the stated selection rule, which draws from relevant cross-area patterns and the reported control positions. The selection does not grade or rank exposures, and it does not imply that unselected items require no action. The wider control register contains 55 items, while this report develops 5 observations for leadership discussion.

PEOPLE, PAYROLL AND INSIDER RISK

Salary changes can be redirected when payroll replies to the initiating request

The organisation reports that employee bank-detail changes are confirmed by replying to the email or form that requested the change. The reported practice does not require HR or payroll to start a separate contact through a telephone number already on file or an in-person check before the amendment takes effect.

An impersonator who submits a plausible request may control both the original message and the response route. If payroll accepts the request and confirms it within the same channel, salary payments could be redirected without the real employee being aware of the change until payment is due. The speed of payroll processing can leave limited opportunity to reverse a change once a payment cycle has progressed.

The HR and payroll lead should establish a procedure requiring every bank-detail change to be confirmed through a channel started by the organisation before it takes effect. The chief financial officer is accountable for the control, and the operating process should retain a clear confirmation trail, including approved exceptions where they are necessary.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Bank changes confirmed with employee: partly in place	HR and payroll lead	60 days (proposed)

PEOPLE, PAYROLL AND INSIDER RISK

Hiring can admit a false identity when documents are accepted on appearance

The organisation reports that a copy of an identity document is obtained during hiring, but the identity is not checked against Home Affairs records. A document copy alone may not establish whether the person presenting it is the person named on it or whether the information is authentic.

A dishonest applicant could seek employment using a stolen or invented identity, or could provide credentials that are not their own. If that person gains employment, payroll access, physical access or authority over operational information may follow. The difficulty of correcting the position can increase once the person has entered ordinary employment and payment processes.

The HR and payroll lead should ensure that each new employee's identity is checked against Home Affairs records, for example through an appropriate service, before the start date. Payroll should not enable salary payment until the identity-check result is available in the personnel record, with the chief financial officer accountable for the control design.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Identity verified: partly in place	HR and payroll lead	60 days (proposed)

FINANCE, BANKING AND FINANCIAL REPORTING

Fraudulent beneficiaries can be introduced when finance follows contact details in the request

The organisation reports that a request for a new beneficiary is confirmed by replying to the email or calling a number contained in the request. This means the organisation may rely on contact details selected by the person seeking the payment.

An impersonator could send an invoice or payment request that appears to come from a legitimate party, then answer the confirmation through a controlled email address or telephone number. If finance accepts that exchange as sufficient confirmation, funds may be released to an account selected by the impersonator rather than the intended recipient.

The finance lead should require a call to a number already held on the relevant record before a payment to a new beneficiary is released. Finance staff should not treat an email reply or a contact number contained in the instruction as sufficient on its own, and the chief financial officer should oversee adoption of the procedure.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	New beneficiaries confirmed by call-back: partly in place	Finance lead	60 days (proposed)

CUSTOMERS, REVENUE AND PRODUCTS

Customer changes can redirect funds or goods when unusual appearance is the trigger for challenge

The organisation reports that changes to customer refund accounts, delivery addresses and contact numbers are checked only when they appear unusual. The reported approach does not require every relevant change to be confirmed with the customer through details already held by the organisation.

A customer account can appear ordinary even when an attacker has obtained access or has persuaded staff that a change is genuine. An amended delivery address may redirect goods, while a changed refund account or contact number may redirect money or prevent the genuine customer from receiving notices that would reveal the activity.

The commercial and customer lead should introduce a consistent process in which customer detail changes are confirmed through existing contact details and implemented by someone outside sales. The chief financial officer is accountable for the control, and the procedure should ensure that a requestor cannot both initiate and complete the amendment.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Customer detail changes verified: partly in place	Commercial and customer lead	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A help desk reset can give an impersonator access to an employee account

The organisation reports that help desk staff call a person back on a number given by the caller when handling password or multi-factor reset requests. That practice does not create an independent route for establishing whether the caller is the employee whose account is being reset.

An impersonator could claim a lost phone or urgent access problem, provide a controlled telephone number and receive a reset that enables them to sign in as a genuine employee. Once inside an account, the attacker may attempt to change bank details, obtain information or release payments under an identity that appears legitimate in normal system activity.

The IT lead should stop using caller-supplied contact details as the basis for reset confirmation and use a number already held on file or a manager's confirmation through a known channel. The chief financial officer is accountable for this control, and the procedure should preserve a clear account of each reset and any authorised exception.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Help desk resets verified: partly in place	IT lead	60 days (proposed)

HOW FRAUD EXPOSURE COULD MATERIALISE

A compromised help desk process can support payment diversion through a genuine employee account

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

An impersonator can turn a reset request into access that appears legitimate

An outsider could contact the help desk or IT provider while impersonating an employee and claim that a password or multi-factor method has been lost. The opportunity arises where reset confirmation depends on the caller's word or on a telephone number chosen by that caller.

If the reset is completed, the outsider may sign in as the employee and use the account to seek changes to bank details or payment activity. Where other functions also confirm requests through requester-controlled channels, the outsider may attempt to influence those confirmation routes as well. Activity under a genuine account can look like ordinary work unless staff recognise the sequence of reset, sign-in and payment-related activity.

Warning signs include a reset request that claims urgency or a lost phone, a reset followed closely by payment or bank-detail activity, a sign-in from an unfamiliar device or location, and an employee unaware of a reset made in their name. Containment should include locking the account, reversing changes where possible, contacting the bank about any payment, and preserving help desk and sign-in information. The long-term response is independent reset confirmation and strong sign-in protection for systems that move money.

WARNING SIGNS

- A reset request claiming a lost phone or urgency
- A reset followed quickly by payment or bank-detail activity
- Sign-ins from an unusual location or device
- An employee unaware of a reset made in their name

FIRST RESPONSE

Lock the account, reverse the changes, contact the bank about any payment, and preserve the help desk and sign-in records.

LASTING CONTROL

Every password or multi-factor reset is verified through a route the caller does not control, and systems that move money require strong sign-in.

WHAT MANAGEMENT SHOULD DO FIRST

The controls set out first can reduce direct routes to diversion and impersonation

FIRST RESPONSES

RESPONSE	ACCOUNTABLE EXECUTIVE	PRACTICAL OWNER	PROPOSED STAGE	SUCCESS MEASURE
Bank changes confirmed with employee	Chief financial officer	HR and payroll lead	60 days	Every change to an employee's bank details made in the period was confirmed through a channel the organisation started before it took effect, or is a recorded and approved exception.
Identity verified	Chief financial officer	HR and payroll lead	60 days	Every new employee in the period has an identity verification result showing identity verified against Home Affairs records before the start date.
New beneficiaries confirmed by call-back	Chief financial officer	Finance lead	60 days	Not yet in the library. The method's level 4 description is the target: every payment to a new beneficiary is confirmed by calling the requester on a number already on record before release.
Customer detail changes verified	Chief financial officer	Commercial and customer lead	60 days	Every change to customer details in the period was verified with the customer through details already on file before it took effect, and was made by someone outside sales.
Help desk resets verified	Chief financial officer	IT lead	60 days	Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception.
Route for allegations against senior people	Chief executive	Board or audit committee	60 days	Not yet in the library. The method's level 4 description is the target: a written route takes allegations about any executive or board member to an independent recipient, and people know it exists.

Responses are listed in the order the work should start, which is not a ranking of fraud risk. Stages are proposals for management's own plan, not deadlines. Full specifications, records and failure responses are in the supporting workbook.

Independent salary-change confirmation can prevent payroll diversion

Every employee bank-detail change should be confirmed through a channel initiated by the organisation, such as a call to a number already on file or an in-person confirmation, before the change takes effect. The process should make clear that a reply to the initiating email or form cannot stand alone as confirmation.

The chief financial officer is accountable and the HR and payroll lead is the practical owner. During the proposed implementation stage, the organisation should ensure that each bank-detail amendment has confirmation through an organisation-started channel before it takes effect, unless an approved exception is retained with the supporting reason.

Identity checks before employment can reduce false-entry opportunities

Each new employee should have their identity checked against Home Affairs records, for example through an appropriate service, before starting employment. The outcome should be held in the personnel process so payroll can establish that the required check has occurred before salary payment is enabled.

The chief financial officer is accountable and the HR and payroll lead is the practical owner. The proposed implementation stage should result in an operating process where each new employee has an identity-check outcome before the start date, allowing payroll and HR to apply the same requirement consistently.

A call to an established contact can protect new-beneficiary payments

Each payment to a new beneficiary should be confirmed by calling the requester through a telephone number already held on the organisation's records before payment release. This prevents an email reply or a number supplied in the request from becoming the sole source of assurance.

The chief financial officer is accountable and the finance lead is the practical owner. The proposed implementation stage should establish a payment process in which new-beneficiary confirmation is completed before release and finance retains the information needed to show how the independent contact was made.

Customer changes should require independent contact and separation from sales

Each amendment to a customer refund account, delivery address or contact number should be confirmed with the customer through details already held on file. A person outside sales should make the amendment after the confirmation, preventing the same role from receiving and completing the change.

The chief financial officer is accountable and the commercial and customer lead is the practical owner. The proposed implementation stage should establish a procedure under which customer changes take effect only after independent customer contact and completion by a non-sales role.

Help desk reset controls can reduce account takeover through impersonation

Every password or multi-factor reset should be confirmed through a route the caller does not control, such as a call to a number already held on file or manager confirmation through a known channel. Help desk staff should have clear guidance that an incoming caller's confidence, urgency or supplied number is not enough.

The chief financial officer is accountable and the IT lead is the practical owner. During the proposed implementation stage, the organisation should ensure that every reset is independently confirmed before it takes effect, with authorised exceptions retained alongside the reason for the exception.

An independent route for senior allegations can support fair escalation

A written route should take allegations about any executive or board member to an independent recipient, and people should know that route exists. This helps prevent seniority from becoming a reason that concerns are handled informally or remain within the reporting line affected by the allegation.

The chief executive is accountable and the board or audit committee is the practical owner. The proposed implementation stage should establish the written route, identify the independent recipient and communicate the route so that employees understand how to raise a concern involving senior people.

A 30, 60 AND 90 DAY RESPONSE

The proposed stages move from ownership to operation and oversight reporting

THE FIRST NINETY DAYS, IN PROPOSED STAGES

30 days

PROPOSED STAGE

Establish the facts, name the owners and decide the order of work.

- Every outstanding question answered, or an open item with an owner
- Each open area has a named accountable executive
- The order of work is recorded with the factors behind it

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

60 days

PROPOSED STAGE

Approve the design, owner and record for each priority control, and schedule its first operating cycle.

- Bank changes confirmed with employee
- Identity verified
- New beneficiaries confirmed by call-back
- Customer detail changes verified
- Help desk resets verified
- Route for allegations against senior people

OWNERS

HR and payroll lead, Finance lead, Commercial and customer lead, IT lead, Board or audit committee

90 days

PROPOSED STAGE

Start operating the priority controls and report status to the oversight body.

- Each priority control has run at least once and kept its record
- Status reported to the board or its audit or risk committee

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

The proposed opening stage should resolve unanswered controls and name owners

The proposed opening stage is intended to establish the facts, name accountable executives and decide the order of work. Its expected outcome is that every outstanding question is answered or remains open with an owner, while each open area has a named accountable executive.

The legal and compliance lead, fraud risk lead, HR and payroll lead, finance lead, IT lead and chief executive should contribute to this work. Leadership should retain a concise explanation of why the work is sequenced as it is, so that the board or its committee can understand ownership, dependencies and any requirement for further support.

The proposed implementation stage should approve control designs and schedule operation

The proposed implementation stage should approve the design, owner and operating record for each control set out first in this report. It is the point at which payroll, finance, commercial and customer teams, IT and the board or audit committee translate the required control outcomes into procedures that staff can follow.

Expected outcomes include independent confirmation for bank changes, identity checks before employment, new-beneficiary call-backs, customer-detail confirmation, help desk reset controls and an escalation route for allegations involving senior people. Each owner should know what action starts the control, who completes it, what exception route applies and what information is retained.

The proposed operating stage should produce control activity and oversight visibility

The proposed operating stage is intended to begin routine use of the selected controls and provide a status report to the board or its audit or risk committee. Each control should have operated at least once and have supporting information available for management review.

The chief executive and functional owners should provide oversight with a concise account of implementation status, exceptions, unresolved ownership issues and any further actions required. The purpose is to give leadership visibility of whether the proposed procedures are being used and whether new issues have emerged during initial operation.

BASIS OF THIS REPORT

This assessment reflects the organisation’s own answers and pending method approvals

Every finding and recommendation rests on the organisation’s own answers. MK has not reviewed documents, interviewed staff or assessed controls in operation, and the supporting information named in this report is information management should maintain rather than material reviewed by MK. Independent evidence review is outside this assessment and would require separate scope and pricing.

Unanswered questions are treated as open items requiring an owner and an answer. The assessment compared 0 answer pairs under the reviewed relationship table, and no answer pairs require settlement or clarification. This does not mean that all control arrangements are known, because outstanding answers remain with the relevant functions.

No approved readiness conclusion is issued because the relevant readiness method, band and threshold remain pending approval. The priority of findings and risks also remains subject to selection rules until an approved prioritisation approach exists. Control, scenario and decision content remains draft content for approval.

MANAGEMENT CONCLUSION

Leadership can reduce direct fraud routes by establishing ownership and operating independent checks

The organisation should recognise that the reported position is shaped by both broad control gaps and a repeatable weakness in how requests are confirmed. A convincing email, telephone call or message can be controlled by an impersonator, which is why independent contact routes and clear separation of duties are central to the actions set out in this report.

The sensible next step is to resolve unanswered controls, give accountable executives and practical owners clear responsibilities, and then establish the selected payroll, identity, payment, customer, help desk and allegation controls. The chief financial officer should coordinate the operational safeguards with the functional leads, while the chief executive and board or its audit or risk committee maintain oversight of progress.

By the end of the proposed operating stage, each selected control should have been used, supporting information should be available to management, and status should have reached the board or its audit or risk committee. That approach gives the organisation a practical route from uncertainty and requester-controlled confirmation towards clearer accountability and stronger resistance to diversion and impersonation.

Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Kestrel Freight (Pty) Ltd (fictional) on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Restricted test; not for customer release.